1. Agent security incidents are increasingly the norm

Point we want to make	Supporting stats
A majority of orgs have experienced agent security incidents. This is consistent with what we found from the DevOps/developer side in the State of Agent DLC report. When these incidents are severe, the consequences skew toward breach and compliance, not downtime or lost engineering time	(Q23) Which of the following agent-related incidents has your organization experienced in the past 12 months?: ● 62% (multiple times or one-off): An agent accessed data or systems outside its intended scope (31% multiple times) ● 56% An agent was connected to MCP servers or tools without security's knowledge (27% multiple times ● 57%: An agent was manipulated via prompt injection into taking an unintended action (24% multiple times) ● 55% consequential action w/o approval ● 54%: An agent chained tools or actions in an unexpected or harmful way (25% multiple times) 53%: An agent leaked sensitive data in its output or logs (24% multiple times) ● 51%: An agent's identity was compromised or impersonated (25% multiple times)
	Supporting stat from State of Agent DLC report: ● 87% had at least one tangible agent-related issue this year
	Supporting stats from State of Agent DLC report: ● 14%: among 7 "most severe consequence" categories, customer data exposure is most common ● 13%: regulatory/compliance finding close behind ● 11%: both ahead of revenue loss, downtime, and reputational impact individually (~11% each) ● 28%: cite data privacy concerns as a driver of an issue this year
The problem is already running at real scale at the mean.	(Q1 a-c) How many distinct AI agents do you estimate are running in production or development in your organization today? ● 18632 (mean): in widespread production ● 13492 (mean): in pilot phase ● 14212 (mean): as prototypes in development Growth in number of agents: ● 65% expect the number of agents to grow 50% or more in the next 12 months

A meaningful tail of organizations are already operating at extreme scale.	(Q1d) How many distinct AI agents do you estimate are running in production or development in your organization today? ● 150,000+: 5% ● 100,000-150,000: 10% ● 50,001-100,000: 18%
And most expect it to keep growing: over half expect the agent count to grow 50% or more in the next year	(Q2) In the next 12 months, how do you expect the number of AI agents in your organization to increase or decrease? ● 52%: increase by over 50% ● 41%: increase by up to 50% ● 5%: stay the same ● 2% decrease

2. Confidence is high and doesn't track either the security controls in place or resulting outcomes

Point we want to make	Supporting stats
Confidence in detection is high.	(Q14c) My organization is fully prepared to detect and respond to an AI agent behaving maliciously or erratically: ● 41%: strongly agree ● 51%: somewhat agree ● 5%: somewhat disagree ● 3%: strongly disagree
And so is confidence in visibility.	(Q14b) Our security team has full visibility into every AI agent operating across the business, including ones spun up by individual teams or developers: ● 43%: strongly agree ● 44%: somewhat agree ● 10%: somewhat disagree ● 3%: strongly disagree
But that confidence doesn't track outcomes: a companion study found virtually no gap between confident and non-confident orgs' incident rates	Supporting stat from State of Agent DLC report: ● No statistically significant relationship between security confidence and incidents. Confident orgs had an 88% incident rate vs. 87% for everyone else

Leaders are more confident than practitioners they they have visibility	(Q14b) Our security team has full visibility into every AI agent operating across the business, including ones spun up by individual teams or developers ● 91%: of leaders agree ● 84% of practitioners agree
And on who's accountable	(S6) As part of your role, are you involved in ensuring the secure development and use of AI within applications? ● 90%: of leaders say "Yes, directly responsible" ● 70%: of practitioners say "Yes, directly responsible"
Respondents believe their organizations have strong policies in place	(Q14d) My organization's policies governing the development and deployment of AI agents are mandatory, consistently applied and technically enforced: ● 47% strongly agree ● 44% somewhat agree ● 6% somewhat disagree ● 2% strongly disagree
Despite that, respondents believe that unsanctioned agents are a major blind spot	(Q14a) Unsanctioned ('shadow') AI agents represent a bigger blind spot than shadow IT did in years past: ● 33% strongly agree ● 47% somewhat agree ● 14% somewhat disagree ● 5% disagree
Security teams routinely discover agents they didn't know existed, directly contradicting the 87% visibility claim	(Q17 a-f) Areas where the organization had discovered an agent operating that security wasn't aware of: ● 66% (multiple times or one-off): Software development, coding or testing (41% multiple times) ● 66%: Data analysis, reporting or business intelligence (41% multiple times) ● 64%: IT operations, infrastructure or cloud management (38% multiple times) ● 62%: Customer service, sales or marketing (37% multiple times) ● 61%: Finance, legal, HR or other corporate functions (29% multiple times) ● 58%: Cybersecurity monitoring, detection or response (37% multiple times)
Respondents believe their organizations are highly exposed to agent incidents	(Q22 a-g): ● 69% (significant or moderate exposure): An agent accessing data or systems outside its intended scope (28% significant)

	• 68%: An agent taking consequential actions without human approval (30% significant) • 64%: An agent leaking sensitive data in its output or logs (32% significant) • 64%: An agent being manipulated via prompt injection into taking an unintended action (30% significant) • 64%: An agent connecting to MCP servers or tools without security's knowledge (30% significant) • 64%: An agent chaining tools or actions in an unexpected or harmful way (28% significant) • 62%: An agent's identity being compromised or impersonated (29% significant)
And that belief is borne out: this is the same incident data from Theme 1, restated here to close the loop between perceived exposure and actual occurrence	(Q23 a-g): Which of the following agent-related incidents has your organization experienced in the past 12 months? • 62% (multiple times or one-off): An agent accessing data or systems outside its intended scope (31% multiple times) • 57%: An agent being manipulated via prompt injection into taking an unintended action (24% multiple times) • 56%: An agent connecting to MCP servers or tools without security's knowledge (26% multiple times) • 55%: An agent taking consequential actions without human approval (25% multiple times) • 54%: An agent chaining tools or actions in an unexpected or harmful way (25% multiple times) • 53%: An agent leaking sensitive data in its output or logs (24% multiple times) • 51%: An agent's identity being compromised or impersonated (25% multiple times)

3. Agent security is currently a patchwork of controls

Point we want to make	Supporting stats
There are a lot of controls required for agent security. The controls that organizations do have are partial and uneven.	(Q18) Which of the following measures or capabilities, if any, does your team have in place to evaluate and manage the security posture of AI agents? • 57%: Identity, access and permissions controls that limit which systems, data and tools AI agents can use • 55%: Runtime monitoring and enforcement to prevent tool misuse, prompt injection and sensitive-data exfiltration

	• 51%: End-to-end tracing and audit logs covering agent prompts, reasoning, tool calls, actions and outputs • 49%: A comprehensive inventory of AI agents across the organization • 49%: Enforced threat modelling of AI agent risks (e.g., prompt injection) before any new application is deployed • 48%: Adversarial testing of AI agents for unexpected behavior, prompt injection and policy violations before deployment • 37%: Governance and oversight of Model Context Protocol (MCP) usage
And even where controls exist, none of them clearly reduces incident rates on their own	Supporting stat and quote from the State of Agent DLC report: • Only 23% have a dedicated agent-security layer live in production (29% piloting) • We also checked whether any single security control tracked with fewer incidents. None did. Organizations with a given control and those without it reported incident rates that differed by only a few points
The MCP surface is mostly third-party…	(Q9) Approximately what percentage of the MCP servers and tools that your organization's AI agents connect to were built in-house (i.e. not sourced from third-parties)? • 39%: mean (that means 61% mean are third-party)
…sits on the weakest-governed control…	(Q18) Which of the following measures or capabilities, if any, does your team have in place to evaluate and manage the security posture of AI agents? • 37%: Governance and oversight of Model Context Protocol (MCP) usage
…and has the highest incident rate of any category.	(Q23 a-g): Which of the following agent-related incidents has your organization experienced in the past 12 months? • 56%: An agent connecting to MCP servers or tools without security's knowledge (26% multiple times)
This gap is recognized industry-wide.	Supporting stat from State of Agent DLC report: • 36% of 15 options: OWASP LLM/MCP risk testing tops the list of capabilities needed to scale safely
Inventory and discovery are also fragmented	(Q10) Which of the following best describes the way your organization inventories and monitors the APIs that AI agents use to access data, systems, and services? • 37%: APIs are automatically recorded in a central inventory and are continuously monitored and governed

	● 24%: APIs are documented manually by individual teams or application owners in their own inventories and monitored periodically ● 22%: APIs are automatically recorded in a central inventory, but monitoring is limited or periodic ● 12%: Practices vary significantly between teams, environments or business units ● 3%: We do not currently maintain an inventory of the APIs used by AI agents
Same point	(Q15) How does your security team usually identify where AI agents are in use across your organization? ● 63%: We use automated discovery to continuously identify AI agents as they are deployed or become active ● 60%: We monitor access controls for AI agents ● 55%: We monitor API traffic ● 50%: We are constantly carrying out inventory with developers ● 36%: We check with finance to see where spend is going ● 1%: We don't check for AI agent usage
Most developers loop security in before production, but as a notification, not a required gate	(Q19): How do developers within your organization work with security to test their AI agents? ● 52%: Developers give the security team a chance to review AI agents before they go into production ● 24%: Developers notify the security team before they create a new AI agent, but don't need to wait before moving it to production ● 15%: Developers let the security team know about a new AI agent after it's in production ● 7%: Developers only let the security team know when a new AI agent has been the subject of a security incident ● 2%: Developers don't usually involve security teams when building AI agents
And that gate is often missing entirely: most orgs run partial evals with no rule that actually blocks a bad release	From the developer perspective: supporting stats from the State of Agent DLC report: ● 74% confident their evals would catch a bad release ● Only 19% actually have a gate that blocks every bad release automatically ● Average org runs 4 of 11 eval methods, no single method clears 46% adoption ● 42% of orgs promoting agent changes to production have no fixed standard for the decision (31% ad hoc, 11% no process)

However, agents are being deployed faster than security can keep up with	(Q21a) Employees are deploying AI agents faster than security teams can assess the risks they create: ● 28% strongly agree ● 43% somewhat agree ● 17% somewhat disagree ● 12% strongly disagree
And security teams agree, naming pace of adoption their top barrier	(Q25): ● 42: Pace of AI agent adoption outstripping the capacity of security teams to review
A companion study finds the same thing: security/permissions risk is the top-cited barrier to scaling agents industry-wide	Supporting stat from State of Agent DLC report: ● 30%: security/permissions risk is the single largest cited barrier to scaling agents ● 28%: ahead of lack of observability ● 27%: ahead of compliance/audit concerns

4. Risk isn't confined to agent behavior. It's also in the code and in who's allowed to build.

Point we want to make	Supporting stats
AI-generated code carries its own, distinct security issues	(Q8) Which of the following issues has your organization encountered in AI-generated or AI-modified code? ● 48%: Code that developers could not adequately explain or maintain ● 45%: Security vulnerabilities ● 42%: Proprietary code, credentials or sensitive data being shared with AI tools ● 39%: Licensing, copyright or provenance concerns ● 37%: Fabricated or non-existent packages, libraries or APIs ● 37%: Insecure or outdated dependencies ● 9%: We have not identified any of these issues
How that code gets secured is its own patchwork, no single method is close to universal	(Q7) How does your organization assess AI-generated or AI-modified code before it is released? ● 60%: It receives additional automated security scanning ● 58%: The AI tool used and the code's provenance are recorded ● 55%: It follows the same security-testing process as human-written code

	• 53%: Developers must identify or label AI-generated code • 51%: It receives additional manual or peer review
Non-IT teams can deploy agents largely without formal security involvement	(Q16 a-g) Are each of the following teams in your organization allowed to deploy their own AI agents to automate workflows? • 89%: customer service (34% without requiring formal IT or security approval) • 86%: sales (37% without requiring formal IT or security approval) • 86%: marketing (33% without requiring formal IT or security approval) • 84%: finance (28% without requiring formal IT or security approval) • 84%: HR (34% without requiring formal IT or security approval) • 79%: legal (30% without requiring formal IT or security approval)
And organizations already expect this to cause an incident	(Q14e) Citizen developers (i.e. those in non-IT functions) spinning up unsanctioned AI agents will be the cause of a security incident in the next 12 months: • 28%: strongly agree • 50%: somewhat agree • 17%: somewhat disagree • 5%: strongly disagree

5. Who owns agent security

Point we want to make	Supporting stats
There is not yet an industry-wide standard for who owns agent security in an organization	(Q11) Who is responsible for AI agent security in your organization?: • 38%: A dedicated AI security role/team • 25%: Shared responsibility across multiple teams • 20%: Existing AppSec/product security team • 15%: Platform/DevOps team • 2%: There is no defined owner
...or for how agent security governance is structured	(Q3) Which of the following best describes your organization's approach to AI agent security? • 36%: Each team develops and uses their own AI agents but the organization has centralized governance and visibility

	● 28%: Teams develop and use their own AI agents but share insights and visibility ● 18%: Only AI agents approved by a central committee can be developed and used ● 18%: AI agent development and use is siloed in each department with no communication
Security budgets are increasing overall, but in 1 in 5 organizations, the cost falls on the team that built the agent, not on security	(Q13) How is your organization planning to budget for AI agent security needs in the next 12 months? ● 52%: We're increasing budgets to protect AI agents ● 20%: The teams who build the AI agents will have to cover the cost of securing them ● 17%: We're shifting budgets from other areas to pay for AI agent security ● 5%: We don't have a unique line item for AI agents in our security budgets ● 4%: We're not changing our budgets ● 1%: Don't know / Don't have visibility